

Sesión 4

Bóveda inmutable (WORM)

Object Lock, repositorios append-only y snapshots — la copia que el ransomware no puede destruir

Del backup que se puede borrar a la bóveda que resiste incluso al atacante con credenciales de administrador

Jawy Andrés Romero Pinto · Módulo 92-EAN · Universidad Ean · Educación Continua

2 horas · 1h teoría + 1h laboratorio

Agenda de la sesión

La última línea de defensa: la copia que nadie puede tocar

S3→4

De la Sesión 3 a la 4

Detectamos a la familia; hoy garantizamos desde dónde restaurar.

93%

El backup es el objetivo

El ransomware moderno caza tus copias antes de cifrar.

3-2-1

La regla 3-2-1-1-0

La evolución: una copia inmutable y cero errores de verificación.

WORM

WORM y Object Lock

Write Once, Read Many: de la cinta al candado por software.

A-O

Append-only y snapshots

restic/Borg que no dejan podar la historia; ZFS que rebobina.

LAB

Laboratorio (2ª hora)

Montas la bóveda, la atacas y compruebas quién sobrevive.

La estrella polar (inmutabilidad)

La pregunta del curso, cuando el atacante ya está dentro



«El atacante tiene credenciales de administrador y su siguiente objetivo son los backups: ¿cuál de tus copias seguirá existiendo mañana?»



Inmutable por diseño

No es una política: es física del sistema.
Ni root la salta.



Retención que expira sola

El candado dura N días; nadie —ni tú—
lo abre antes.



El servidor manda

Append-only: el cliente comprometido
no borra historia.



Confianza verificada

FIM (AIDE/Wazuh): sabes que nadie
tocó la bóveda.

De la Sesión 3 a la Sesión 4

De cazar a la familia a garantizar la restauración

Sesión 3 · detección

- Reglas YARA (archivos) y Sigma (logs)
- La regla dispara: vssadmin delete shadows
- Responde QUIÉN fue y dónde más está
- Pero detectar no restaura nada



Sesión 4 · bóveda inmutable

- Cuando la regla dispara, ya es tarde para copiar
- La copia limpia debe EXISTIR de antemano
- WORM + append-only + snapshots
- Responde DESDE DÓNDE restauras con confianza

El backup es el primer objetivo

El ransomware moderno caza tus copias antes de cifrar producción

93 %

de los incidentes de ransomware intentan atacar los repositorios de backup

75 %

de las víctimas pierde al menos parte de sus repositorios de backup

T1490

MITRE: inhibir la recuperación — shadows, catálogos y consolas de backup

1

copia inmutable verificada basta para no pagar el rescate

La lección de la Sesión 3 se voltea: el mismo actor que tú detectas con Sigma está buscando tu consola de backup con las credenciales que robó.

Fuente: Veeam Ransomware Trends Report 2023 (n=1 200 organizaciones; cifras redondeadas).

La regla 3-2-1-1-0

La evolución del 3-2-1 para la era del ransomware



Los dos números nuevos son la respuesta al ransomware:

- El «1» inmutable: aunque el atacante tenga TODAS las credenciales, esa copia no se puede cifrar ni borrar dentro de su retención.
- El «0»: un backup sin prueba de restauración es una promesa — la Sesión 2 (scoring de integridad) es cómo llegas a cero errores.

La bóveda: la metáfora exacta

Lo que compras no es secreto — es imposibilidad de alterar



Puerta de bóveda, Reserve Bank Museum (NZ) · Wikimedia Commons · CC BY-SA 2.0

Tres propiedades que el lab reproduce en software:

- La puerta se abre con llave — igual que tu bóveda acepta credenciales válidas para ESCRIBIR nuevos depósitos.
- Lo depositado no se puede alterar ni sacar antes de tiempo — retención WORM: ni el dueño de la llave lo destruye.
- Hay cámaras y auditoría — FIM: cada intento de manipulación queda registrado y genera alerta.

Robar la llave ya no basta. Ese es exactamente el modelo de amenaza del ransomware moderno.

WORM: de la cinta al Object Lock

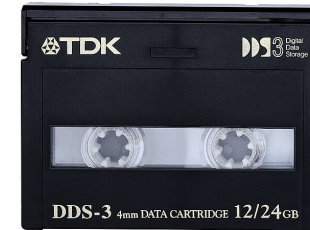
Write Once, Read Many — el concepto tiene 40 años; el candado ahora es software

Ayer: WORM físico

- Cintas LTO con pestaña WORM y discos ópticos: la imposibilidad de reescribir era del MEDIO. El air gap era literal: la cinta en un estante.

Hoy: WORM por software

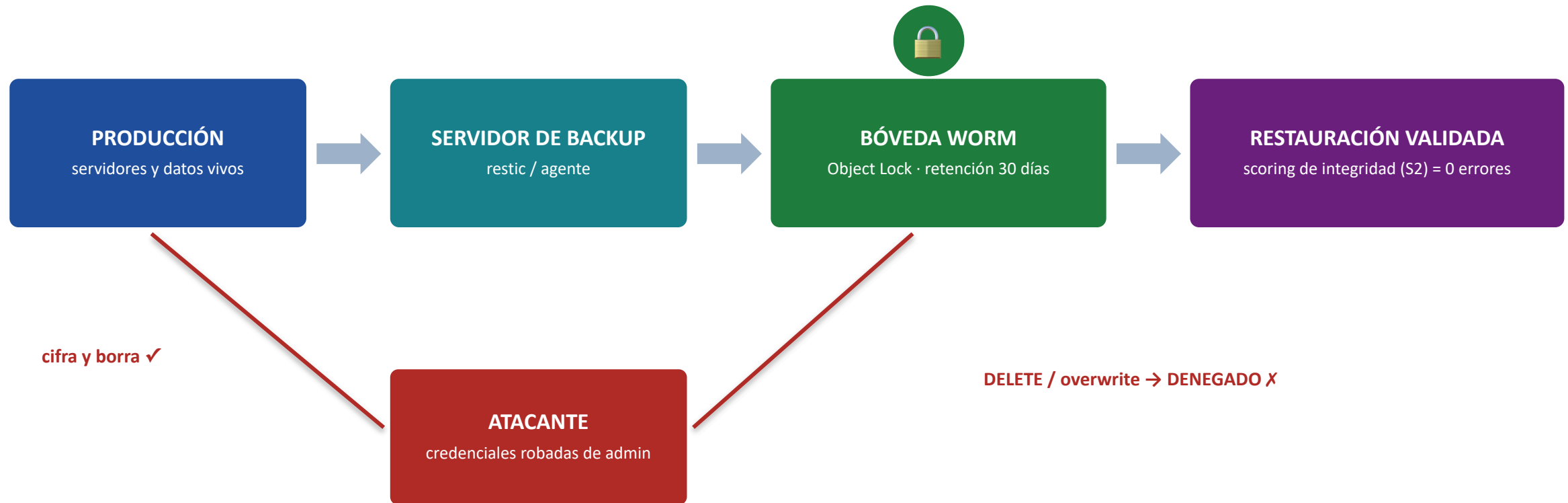
- S3 Object Lock (AWS, MinIO), Azure Immutable Blob: el candado vive en la API del almacenamiento de objetos.
- Retention period por objeto + legal hold sin fecha.
- Modo GOVERNANCE: un rol especial puede levantarlo (útil, pero es una llave más que robar).
- Modo COMPLIANCE: NADIE lo levanta — ni root, ni el proveedor — hasta que expira. Es el modo del lab de hoy.



Cartuchos de cinta (LTO, DDS, 8mm) · Wikimedia Commons · CC BY-SA 4.0

Anatomía de la bóveda (flujo)

El camino del dato — y dónde rebota el atacante



La única flecha que la bóveda acepta es ESCRIBIR un objeto nuevo. Borrar, sobrescribir o acortar la retención rebotan — aunque las credenciales sean válidas. Eso convierte el backup de objetivo en testigo.

Object Lock en la práctica

Lo que vas a teclear en el lab — y su equivalente en la nube

```
# crear bucket con candado (MinIO, S3 API)
mc mb --with-lock local/boveda
mc retention set --default compliance 30d \
    local/boveda

# subir el backup
mc cp backup.tar.gz local/boveda/

# el 'ataque' (con credenciales validas)
mc rm --recursive --force local/boveda/
→ ...Object is WORM protected
```

Reglas del juego

- Object Lock exige VERSIONING: «borrar» solo añade un delete marker; la versión bloqueada sigue ahí.
- La retención es POR OBJETO y por defecto del bucket; se puede ALARGAR, nunca acortar.
- Mismo modelo gestionado: AWS S3 Object Lock, Azure Immutable Blob Storage, Backblaze B2.
- MinIO te da la MISMA API en tu docker compose — por eso el lab es local y gratis.
- *Cuidado: Object Lock protege el objeto, no tu cuenta — borrar el BUCKET/tenant completo se mitiga con MFA-delete y separación de cuentas.*

Append-only: el servidor decide, no el cliente

Si el cliente de backup cae, su llave no puede reescribir la historia

Repositorio clásico (la llave hace todo)

- El mismo host que respalda puede borrar: `restic forget --prune`
- Ransomware en ese host = adiós historial
- Es el patrón por defecto de restic/Borg local
- Cómodo... hasta el día del incidente



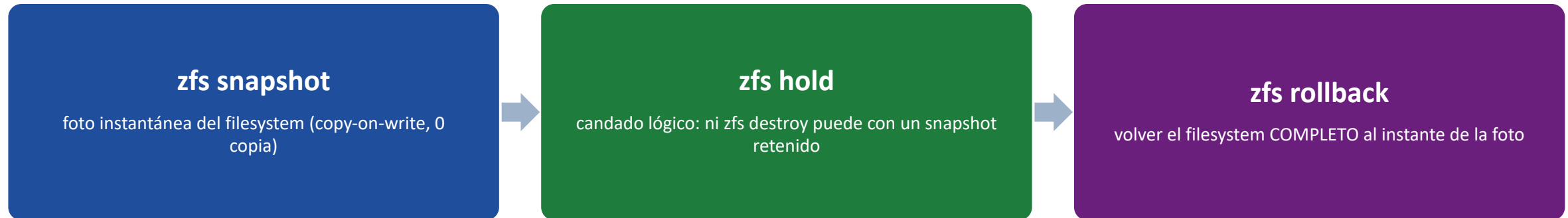
Append-only (rest-server / borg serve)

- El SERVIDOR publica el repo con `--append-only`
- El cliente puede backup y restore, nunca prune/forget
- La poda la hace OTRO host de confianza, programada
- Un cliente comprometido solo puede añadir — no destruir

En el lab: rest-server en docker con --append-only; atacas desde el «cliente comprometido» y el prune rebota con 403.

Snapshots ZFS: rebobinar en segundos

Copy-on-write: la foto no cuesta nada — y se puede retener



Dónde brilla y dónde no:

- Recuperación en minutos tras un cifrado local: rollback y a seguir — el RTO más corto de todo el arsenal.
- Con «zfs allow» quitas el permiso de destroy a la cuenta de servicio: snapshots que el agente no puede borrar.
- PERO vive en el mismo host/pool: si el atacante gana root del sistema de archivos o el hardware muere, se va con todo. Complementa a la bóveda externa — no la sustituye.
- *En Ubuntu: zfsutils-linux sobre un archivo loopback — así lo demuestra el docente hoy (opcional en tu VM).*

¿Quién vigila a la bóveda? — FIM

Integridad de archivos: la cámara de seguridad del backup

AIDE (el inventario notariado)

- Base de datos de hashes de archivos críticos
- aide --init una vez; aide --check programado
- Reporta añadidos / cambiados / borrados
- La base se guarda... en la bóveda (¡claro!)



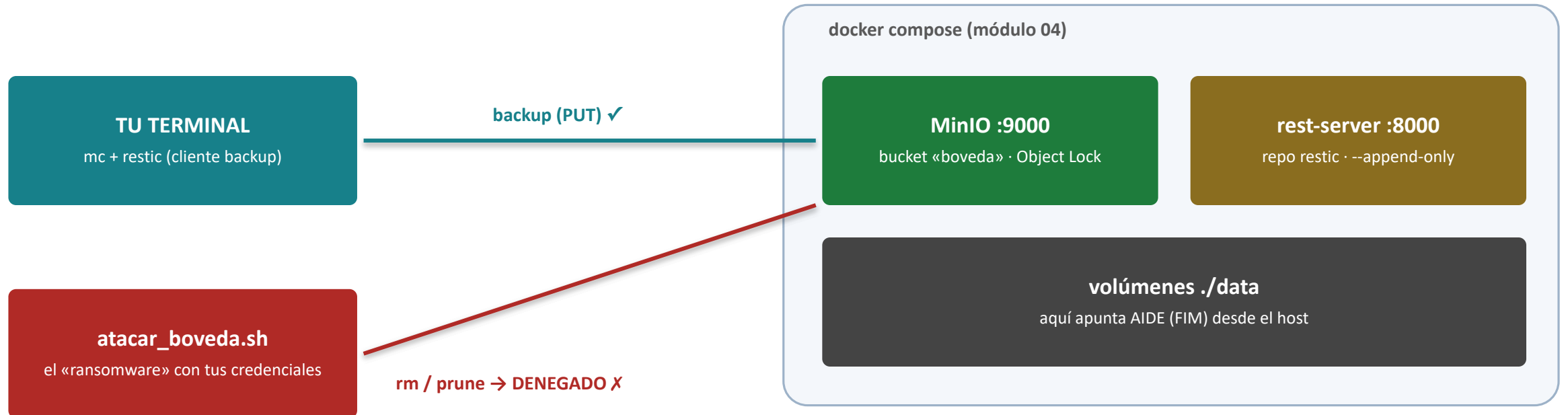
Wazuh FIM (la alarma en tiempo real)

- Agente que vigila directorios al instante (syscheck)
- Alerta al SIEM cuando algo toca la config del backup
- Escala a cientos de hosts con un solo manager
- El paso enterprise del mismo concepto de AIDE

Conexión con la Sesión 2: FIM es tu scoring de integridad, pero corriendo en producción todos los días. En el lab usas AIDE sobre la carpeta de la bóveda.

Arquitectura del lab de hoy (flujo)

Todo en tu máquina: docker compose + restic + AIDE — atacante incluido



Parte 1 (30'): montar MinIO con Object Lock, subir el backup y fallar al destruirlo. · Parte 2 (25'): repo restic append-only vs repo desprotegido — el mismo ataque, dos finales. · Parte 3 (25'): AIDE detecta la manipulación y tú restauras desde la bóveda.

Laboratorio (2ª hora)

Montas la bóveda, la atacas con tus propias credenciales y compruebas quién sobrevive

Parte 1 · 30 min

La bóveda WORM

MinIO + Object Lock COMPLIANCE: bucket normal vs bóveda ante el mismo «ataque».

Parte 2 · 25 min

Append-only al ataque

restic + rest-server: el prune malicioso rebota; el repo desprotegido muere.

Parte 3 · 25 min

Vigilar y restaurar

AIDE detecta la manipulación; restauras desde la bóveda y verificas con hashes (S2).

Requisitos: VM Ubuntu (o Mac) con docker — `setup.sh --with-docker` del core. Todo el dataset es sintético; el «ransomware» es un script que usa tus credenciales válidas: si la bóveda resiste eso, resiste al real.

Puente a la Sesión 5

Ya tienes la copia intocable — falta saber QUÉ hacer a las 3 a. m.

La bóveda responde DESDE DÓNDE restaurar. El runbook responde CÓMO — y en plena crisis nadie recuerda el runbook. Sesión 5: un copiloto RAG local que responde con TUS procedimientos, sin sacar datos de la sala.

- Hoy: la última línea de defensa técnica quedó en pie — y probada contra un atacante con credenciales.
- El checklist 3-2-1-1-0 queda cubierto: la bóveda es el «1» inmutable, el scoring de S2 es el «0».
- Tarea antes de S5: trae (o inventa) el runbook de recuperación de tu organización — será el corpus del RAG.